• Merrowfield Digital · Security Operations

BreachWatch AI

Security incident triage and breach reporting: deciding who must be told, and by when, without missing a legal deadline.

Project overview for the whole team. Plain-English first, with a technical appendix at the end.

1 · The computer does the maths

Laws, deadlines, totals and hours, worked out by code and trained models.

2 · AI writes the explanation

Five AI helpers turn the facts into a briefing. They never change a number.

3 · A person decides

Nothing is sent to a regulator or customer without the Data Protection Officer.

Contents

01 Executive summary

02 The problem in plain words

03 The three reporting rulebooks

04 Why this is hard

05 How BreachWatch works

06 Worked example: one incident, start to finish

07 The AI workflow and the human sign-off

08 Who can do what

09 Data quality and the three models

10 Project structure

11 Running the system

12 Frequently asked questions

13 Glossary

14 Appendix: technical reference

> **How to read this document.** Sections 1–8 explain the problem and the solution without technical terms. Sections 9–11 describe the data, code and setup. The appendix collects the technical names (settings, functions, endpoints and database tables) for engineers.

01 Executive summary

Merrowfield Digital runs an online marketplace with about **9 million customers** and **60,000 sellers** across Europe and India. When a security incident happens, the law may require the company to tell certain authorities, and sometimes its customers, within a few hours. **BreachWatch AI** helps the security team get that right every time.

9M	60K	4	3	16	5–7
customers	sellers	security hubs, 24/7	reporting laws	company PDFs	AI calls per incident

What it does, in one sentence

It **ranks** open incidents by how close each is to a legal deadline, **works out** every authority that must be told and by when, **drafts** a recommendation, and then **stops**, so that nothing is filed and no customer is told on the word of an AI.

The core design idea

Computer: the maths

Which laws apply, when each deadline falls, how many hours are left, how many customers are affected across an attack. Done by ordinary code and trained models, identically every time, so it can be audited.

AI: the words

Five AI helpers each write one part of a briefing, using only the facts they are given. They are explicitly told never to recalculate or change a number.

Person: the decision

The Data Protection Officer reads the briefing and decides, with a written reason. The pause is saved, so it survives a restart.

What the team gets

- An incident list sorted by real urgency, with the deadline that is due *first* at the top.
- For each incident: which laws apply and why, every deadline, the risk to customers, the likely attack type, and whether there is time to finish the work.
- A ready-to-read briefing and recommendation, plus draft regulator reports and customer notices once a decision is made.
- A complete audit trail: every assessment, decision, AI call and chat question is recorded.
- A chat assistant that answers only from company documents and refuses rather than guessing.

> **Why it matters.** Report too late and the company has a legal failure on the record that regulators read at inspection. Report when nothing had to be reported and three authorities hear about something that never affected a customer. Both mistakes are costly.

02 The problem in plain words

No technical knowledge is needed for this section.

01
A big online marketplace
Merrowfield Digital runs an online marketplace with about 9 million customers and 60,000 sellers across Europe and India.

02
A security team that never sleeps
Security teams in four cities (Bengaluru, Lisbon, Warsaw and Tallinn) watch for problems around the clock. Each records times in its own local time zone.

03
Most alarms are nothing
A blocked login, a harmless scan. But a few are real: a database left open, passwords stolen by a fake login page, a laptop left in a taxi, a spreadsheet emailed to the wrong person.

04
The law sets a stopwatch
When something real happens, the law says certain authorities must be told within a time limit. There are three different rulebooks, each with its own authority and its own time limits, starting from different moments.

05
Two ways to get it wrong
Report too late and the company has broken the law on the record. Report when there was no need and three authorities hear about something that never affected a customer.

06
Too much work, too few people
There are more alerts than analysts. The most urgent incident doesn’t always reach the decision-maker first, and the deadline everyone remembers is often not the one that is due first.

> **An everyday comparison: a hospital emergency room.** A triage nurse doesn't treat patients in order of arrival. They check who is most urgent and send them to the right doctor. BreachWatch does the same for security incidents: the most urgent go to the top, it works out which authorities must be told and by when, and it prepares the paperwork. The senior doctor, here the Data Protection Officer, still makes the call.

The four security hubs

Hub	Time zone	Incident references start with
Bengaluru	Asia/Kolkata	`INC-BLR-…`
Lisbon	Europe/Lisbon	`INC-LIS-…`
Warsaw	Europe/Warsaw	`INC-WAW-…`
Tallinn	Europe/Tallinn	`INC-TLL-…`

Each hub records times in its own local time. BreachWatch converts every time to one standard (UTC) and measures every "hours left" figure from one fixed moment: the time the incident list was exported, called the **snapshot**. Everyone therefore sees the same numbers, today and tomorrow.

03 The three reporting rulebooks

Merrowfield must follow three reporting rules, each written in its own PDF document. One incident can fall under one, two, all three, or none of them.

Rulebook	Who must be told	When it applies
Rulebook 1: EU personal data breach GDPR	The EU data-protection regulator (lead supervisory authority)	Applies when personal data of people in the EU was involved and our risk model says the risk to them is serious enough. This rulebook also decides whether customers themselves must be told.
Rulebook 2: Significant ("big") incident NIS2-style	The national cyber-security team (CSIRT)	Applies when the incident is big: a long outage, many customers affected (counting the whole attack), or a large money loss. After the first report, a final report is due some months later.
Rulebook 3: India cyber incident CERT-In	CERT-In, India's national cyber agency	Applies when the affected system is hosted in India, or any Indian person's data was involved. In the sample data, this is often the deadline that falls due first.

Golden rule: no deadlines in the software. The number of hours each rulebook allows is never typed into the code or the settings. The system reads it from each rulebook's own PDF at the moment it is needed. If a rulebook changes, the new deadline is picked up automatically. If a rulebook cannot be read, the system stops with an error instead of guessing.

Deadlines start at different moments

Each rulebook says which moment its stopwatch starts from:

The first alert

The moment any Merrowfield tool first noticed something. It usually comes hours before anyone has confirmed anything.

Awareness (confirmation)

The moment an analyst confirmed the incident is real. Until then, deadlines that count from awareness have not started.

An unconfirmed incident can therefore already have a running deadline. Where several deadlines apply, **the one that falls due first governs the work**. A deadline that has already passed is shown as negative hours (for example −64 h), never as zero.

The deadline that is counted from a filing

One milestone is different: a **final report**, due a number of months after the first report was actually sent. It can only be worked out once a decision to file has been taken.

04 Why this is hard

Different time zones

Four offices each write times in their own local time, in four different notations. Comparing them by eye is easy to get wrong.

Three laws, three stopwatches

Different lengths, different starting moments, different authorities. The deadline everyone remembers is often not the one due first.

Small incidents add up

Several incidents can belong to one attack (a **campaign**). Customers are counted across the whole campaign, so incidents that are small alone can together cross the "significant incident" limit.

Messy data

The spreadsheets arrive with real defects. Nothing downstream may assume a clean table.

Examples of messy data, and what BreachWatch turns them into

Problem	Before	After
Same name typed differently	`" Bengaluru" · "WARSAW " · "seller portal"`	Bengaluru · Warsaw · Seller portal
Spelling varies by person	`"phishing & credential compromise"`	Phishing and credential compromise
"Empty" written many ways	`"-" · "none" · "?" · "N/A" · "Not recorded"`	(blank)
Times written 4 ways, in 4 time zones	`"2025-08-24T07:46:00Z" · "21-Jul-2024 08:37 IST" · "1746610260"`	One standard time (UTC)
Dates written 3 ways	`"2025-04-18" · "22/07/2025" · "27-Oct-2025"`	One date format
Numbers written in words	`"1,20,637" · "1.11 lakh" · "8.7k"`	120637 · 111000 · 8700
Money with currency signs	`"€105,114" · "EUR 178495"`	105114 · 178495
Durations with units	`"2h 30m" · "45 min" · "6 h"`	150 · 45 · 360 minutes
Yes / No written many ways	`"Y" · "TRUE" · "1" · "no" · "0"`	Yes · No
Leftover web code in notes	`"<span>Session token reused from…"`	Session token reused from…
A time gap that doesn't add up	`Says 429 minutes, but the two times are 431 apart`	Recalculated: 431
Confirmed before it was noticed	`Confirmed at 09:00, first noticed at 11:00`	Times put back in the right order
Evidence counted where none was needed	`Forensic image needed: No · Images taken: 3`	Images taken: 0
Note length measured before cleanup	`Length counted with the web code still inside`	Re-measured on the clean text

05 How BreachWatch works

BreachWatch is built from four blocks. Each block hands finished facts to the next, so by the time AI is involved there is nothing left to calculate.

1 · Learn from the past

The messy spreadsheets are cleaned, and every problem found is counted in a quality report as proof. Three models then learn from thousands of past incidents so they can make quick, consistent estimates about new ones: a **risk model** (how likely the affected people are at high risk), a **workload model** (how many analyst hours the work will take) and a **notes reader** (which of eight attack types the analysts' notes describe).

2 · Read the rulebooks

The company's 16 PDFs are the only source of truth. They are cut into short passages and made searchable by meaning. When a deadline is needed, the system searches **only inside that law's own PDF** and reads the number from the sentence. Because the three rulebooks share a template and many identical sentences, searching all of them at once could return the EU deadline when you asked about India, so this is not allowed.

3 · Do the maths

Ordinary, predictable code works out which laws apply and why, when each deadline falls, which one comes first, how many hours are left, and whether the estimated work fits before the deadline once a small filing buffer is set aside. It also sorts the whole incident list: running deadlines first (overdue at the very top), then the rest by risk.

4 · AI helpers and the sign-off

Five AI helpers each write one part of the briefing, using only the facts above. Then the system stops and waits for the Data Protection Officer. The pause is saved to disk, so the machine can be restarted without losing anything.

Worked example: is there enough time? (illustrative numbers)

Item	Value
Hours left until the earliest deadline	12.0 h
Filing buffer kept aside	- 2.0 h
Time available	10.0 h
Work needed (workload model + sensitive-data extra)	13.5 h

Result: it doesn't fit. The briefing will say plainly that the desk has to handle this incident differently.

06 Worked example: one incident, start to finish

A made-up example: a fake login page tricks some sellers into giving away their passwords. Numbers are illustrative; in the real system, deadlines come from the rulebook PDFs.

1

MONITORING TOOL

An alarm goes off

A security tool flags unusual logins on the seller portal. This moment is the "first alert". Any deadline that counts from the first alert starts ticking now.

2

SECURITY ANALYST

An analyst confirms it’s real

An analyst checks and confirms that seller passwords were stolen through a fake login page. This is the moment of "awareness". Deadlines that count from awareness start now.

3

COMPUTER, NO AI

BreachWatch gathers the facts

It pulls the incident’s details: about 4,200 customers in Europe and India, passwords involved. A trained model rates the risk to those people as HIGH. Another model reads the analysts’ notes and agrees it is phishing.

4

COMPUTER, NO AI

Which laws apply?

EU rule: yes (EU customers and high risk). India rule: yes (Indian customers). "Big incident" rule: this incident is part of an attack with three others, and together they cross the customer limit, so yes.

5

COMPUTER, NO AI

When is each deadline?

For each law, it opens that law’s own PDF, reads the time limits from the text, and works out exactly when each one is due and how many hours are left. The earliest one is highlighted.

6

COMPUTER, NO AI

Is there enough time?

A third model estimates how many analyst hours the work will take, with extra time added if the data is sensitive. It compares that with the time left before the earliest deadline, minus a small buffer for filing.

7

5 AI HELPERS

AI writes the briefing

Five AI helpers each write one part: what to check, why the risk is high, how sure we are about the attack type, who must be told and by when, and a final summary with a recommendation. They use only the facts above.

8

DATA PROTECTION OFFICER

A person decides

Everything stops here. The DPO reads the briefing and chooses: just record it, tell the regulator, or tell the regulator and the customers. They must write a reason in their own words.

9

AI + COMPUTER

The documents are drafted and logged

If customers are to be told, the AI drafts the customer notice first, then the regulator report, which says customers were told. Every step, decision and AI call is saved for auditors.

07 The AI workflow and the human sign-off

An assessment runs through ten steps. Six prepare the briefing, one is the human sign-off, and the rest depend on what the Data Protection Officer decides.

Gather the facts — Computer
Loads the incident, its related incidents and its notes. Runs the risk model and the notes reader. No AI writing yet.

Planner — AI helper · 1 call
Reads the analyst's question and lists what needs checking. It plans only and decides nothing.

Risk explainer — AI helper · 1 call
Explains in plain words why the risk is high, medium or low. It may not change the score.

Attack explainer — AI helper · 1 call
Says how sure we can be about the attack type. If the notes mostly disagree, it must say the type is not settled.

Reporting-duties explainer — AI helper · 1 call
The computer first works out which rulebooks apply and every deadline. The AI then writes who must be told and by when, using only the rulebook text.

Report writer — AI helper · 1 call
The computer estimates the hours needed and checks whether they fit before the deadline. The AI writes the final briefing and recommends one of three actions.

DPO sign-off — Person
Everything stops and waits for the Data Protection Officer. The pause is saved to disk, so the computer can even be switched off.

Just record it (5 AI calls)
No one outside is told. The decision and reason are kept on file.

- nothing more to write

Tell the regulator (6 AI calls)
A report is drafted for the authorities. Customers are not contacted.

- **Regulator report writer**

Tell regulator + customers (7 AI calls)
A customer notice is drafted first, then the regulator report, which says customers were told.

- **Customer notice writer**
- **Regulator report writer**

Save everything
Saves the decision, the documents and the final status, and sets the date the final report is due. No AI.

Computer

House rules for the AI

- Exactly one AI call per helper, so the cost per incident is fixed: **5** before the decision, then **+0**, **+1** or **+2**. Every run is checked against this budget.
- Never recalculate or change a number; use only the facts and rulebook passages provided; never apply one law's deadline to another.
- The customer notice never contains internal system names, ticket numbers, staff names, campaign references or guesses about who was behind the attack.
- Every AI call is logged with its size and how long it took.

08 Who can do what

Everyone signs in. Each role sees only the pages its job needs, and the back-end service refuses any request outside a role's permissions. It does not rely on the screens hiding a button.

Role	See the incident list	Run an assessment	Make the final decision	View the history	Use the chat assistant
Data Protection Officer	✓	✓	✓	✓	✓
Security Analyst	✓	✓	—	✓	✓
Customer Communications Agent	—	—	—	—	✓

Data Protection Officer: Can see everything, and is the only person who can make the final decision.

Security Analyst: Does the investigation, but can’t decide whether to notify anyone. Company policy keeps those two jobs apart.

Customer Communications Agent: Only uses the chat assistant, and can’t learn about an incident until customers have been told.

> **Investigating is not deciding.** The Incident Response Plan says the analyst who investigates may not decide whether to notify. That is the reason the workflow stops for a person.

The chat assistant cannot be used to snoop

A Customer Communications Agent writes to customers, so they must not learn about an incident before customers have been told. If they ask about a specific incident before that point, they receive **exactly the same refusal whether the incident exists or not**. Otherwise, asking about made-up references would reveal which ones are real. Once customers have been told, the same question is answered from the published notice and nothing else. Analysts and the DPO are answered from the internal record at any stage.

Other safeguards

- Passwords are never stored, only a salted, scrambled form with a separate salt per account.
- A wrong username and a wrong password show the same error, so nobody can discover which usernames exist.
- The chat answers only from company documents, refuses when they do not cover the question, and never reads the confidential past-cases casebook.
- A decision cannot be recorded twice, and every decision needs a written reason.

09 Data quality and the three models

How much data survived cleaning

Dataset	Received	Kept	Removed	Kept share
Past incidents (training)	30,728	29,715	1,013	96.7%
Past incidents (testing)	8,613	8,308	305	96.5%
Work hours (training)	29,710	28,611	1,099	96.3%
Work hours (testing)	6,132	5,913	219	96.4%
Analyst notes	34,685	32,405	2,280	93.4%

Removed rows were exact duplicates, rows with no answer to learn from, or notes too short to be useful. Every gap left is filled, so the cleaned tables have no empty cells.

The three models

Risk model: "How likely is it that the people whose data was involved are now at high risk?"

It learned from about 30,000 past incidents where the DPO had already judged the risk. For a new incident, it gives a percentage, which is grouped into HIGH, MEDIUM or LOW.

Common-sense checks it must pass: More worried when ID documents are involved; More worried when data was confirmed stolen; More worried when the data was readable rather than encrypted; Gives a spread of HIGH, MEDIUM and LOW, not the same answer for everything.

Workload model: "How many analyst hours will it take to contain this incident and establish the facts?"

It learned from about 29,000 past investigations. If sensitive data (ID documents, health data or children's accounts) is involved, a fixed amount of extra time is added once.

Common-sense checks it must pass: More systems affected → more hours; More logs to review → more hours; Forensic imaging needed → more hours; Attacker still active → more hours; Never predicts zero or negative hours.

Notes reader: "Reading the analysts' quick notes, what kind of attack is this?"

Analysts write fast, in shorthand. This model reads each note and picks one of eight attack types. It also reports how much the notes agree, because notes can disagree.

Common-sense checks it must pass: Can recognise all 8 types, including the rare ones; Doesn't keep mistaking one type for another; Reads every note on the incident, not just the first.

The eight attack types: Phishing and credential compromise · Ransomware · Other malware · Misdirected disclosure · Lost or stolen device · Insider misuse · Cloud misconfiguration · Denial of service.

Each model is tested on a separate set of incidents that was kept aside during training, and each must reach a minimum score set in the configuration.

10 Project structure

The project is split into ten folders, each with a single job.

Folder	In plain words	What it does
`data_pipeline/`	**Cleans up the messy spreadsheets**	Fixes the messy raw data and writes a report showing what was wrong.
`modeling/`	**Trains the three prediction models**	Teaches the risk model, workload model and notes reader, and checks they are good enough.
`knowledge/`	**Reads the 16 policy PDFs**	Turns the company's PDFs into a searchable library and reads deadlines from them.
`tools/`	**Does all the calculations**	Plain code that works out which laws apply, every deadline, and whether there's enough time.
`agentic/`	**Runs the AI helpers**	The step-by-step AI workflow, including the stop for the DPO.
`api/`	**The back-end service**	The service the dashboard talks to. It also checks who you are and what you may do.
`access/`	**Passwords and permissions**	Stores passwords safely and decides which role can open which page.
`chat/`	**The chat assistant**	Answers questions only from the company documents, and refuses when it can't.
`persistence/`	**The database**	Keeps a permanent record of everything for auditors.
`dashboard/`	**The screens people use**	The five pages the team works in.

The 16 company documents

Document	What it covers
`Procedure-01-EU-Personal-Data-Breach.pdf`	EU rulebook
`Procedure-02-Significant-Incident-Reporting.pdf`	"Big incident" rulebook
`Procedure-03-India-Cyber-Incident-Reporting.pdf`	India rulebook
`Incident-Response-Plan.pdf`	Who does what in an incident
`Data-Classification-Standard.pdf`	Which data is high-impact
`Sensitive-Data-Handling-Standard.pdf`	Extra care for sensitive data
`Customer-Communication-Policy.pdf`	What a customer notice must and mustn't say
`Past-Incidents-Casebook.pdf`	Past cases (confidential, never used by chat)
`Playbook-Phishing-And-Credential-Compromise.pdf`	Playbook: Phishing

`Playbook-Ransomware.pdf`	Playbook: Ransomware
`Playbook-Other-Malware.pdf`	Playbook: Other malware
`Playbook-Misdirected-Disclosure.pdf`	Playbook: Sent to the wrong person
`Playbook-Lost-Or-Stolen-Device.pdf`	Playbook: Lost or stolen device
`Playbook-Insider-Misuse.pdf`	Playbook: Insider misuse
`Playbook-Cloud-Misconfiguration.pdf`	Playbook: Cloud setup mistake
`Playbook-Denial-Of-Service.pdf`	Playbook: Service flooded (DoS)

11 Running the system

Six commands, run once in order from the Project folder. Steps 1–4 prepare everything; steps 5 and 6 start the system for people to use.

1 Set up the database

Creates the database and the 15 user accounts people sign in with. Running it again changes nothing.

```
$ python3 run_database_setup.py
```

2 Clean the data

Cleans all five raw spreadsheets and writes a report of every problem it found.

```
$ python3 run_data_pipeline.py
```

3 Train the models

Teaches the three models from past data, tests them, and reports whether each passed its minimum score.

```
$ python3 run_model_training.py
```

4 Build the document library

Turns the 16 PDFs into a searchable library, then proves it can read each rulebook's deadlines from the right PDF.

```
$ python3 run_knowledge_indexing.py
```

5 Start the back-end

Starts the back-end service. If an earlier step was skipped, it says exactly what is missing instead of crashing.

```
$ python3 run_api_service.py
```

6 Open the dashboard

Starts the screens the team uses. Open the address in a browser and sign in.

```
$ python3 -m streamlit run run_dashboard.py
```

Install the dependencies first with `pip install -r requirements.txt`. The back-end runs on port 8082 (interactive API documentation at `/docs`) and the dashboard on port 8501.

12 Frequently asked questions

Why doesn’t the AI just work out the deadlines itself?

Because AI can make mistakes with numbers, and a wrong deadline is a legal problem. Ordinary code does every calculation the same way every time, so an auditor can check it. The AI only writes explanations of numbers it has been given.

Why aren’t the deadlines simply typed into the software?

The rulebooks (PDFs) are the official source. If a rulebook changes, the software picks up the change automatically. If the deadlines were typed into the code as well, there would be two versions that could drift apart.

Why search only one PDF for each law?

The three rulebooks were written from the same template and share many identical sentences. Searching all of them at once could return the EU deadline when you asked about India. So each law is only ever looked up in its own PDF.

Why count from a fixed "snapshot" time instead of right now?

So that everyone sees the same numbers, today and tomorrow, and an auditor can reproduce them. If a deadline has already passed, it shows as negative hours (e.g. −64 h), never as zero.

Why must a person make the final decision?

Company policy says the analyst who investigates must not also decide whether to notify. Telling a regulator or customers is a serious step, so the system recommends and a person decides, giving a written reason.

What if the computer is restarted while waiting for the DPO?

Nothing is lost. The paused workflow is saved to disk, and when the DPO decides later, it carries on from exactly where it stopped.

How many AI calls does one incident use?

5 to prepare the briefing. Then 0 more to just record it, 1 more to tell the regulator, or 2 more to tell the regulator and the customers. The system checks every run used exactly that many.

Why does a wrong username show the same error as a wrong password?

If the messages were different, someone could find out which usernames exist just by trying. One message for both gives nothing away.

Why does the chat refuse even for incidents that don’t exist?

If it said "not found" for fake incidents but "can’t tell you" for real ones, anyone could find the hidden incidents by asking. The same refusal for both reveals nothing.

13 Glossary

Term	Meaning
Incident	Something that has harmed, or may have harmed, a system or the data in it. Example: a customer database left open to the internet.
Campaign	Several incidents that are really one attack. We add up the customers across all of them, because together they can be big enough to report even when each one alone is not.
Snapshot time	The fixed moment the incident list was exported. Every "hours left" figure is counted from this moment, not from the clock on your computer, so everyone sees the same numbers every day.
Maths by code, words by AI	All numbers (risk, deadlines, totals, hours) are worked out by ordinary code and trained models. The AI only receives the finished numbers and writes the explanation. It never calculates anything.
Awareness (confirmation)	The moment an analyst confirms the incident is real. Some deadlines start counting from here. If nobody has confirmed it yet, those deadlines have not started.
First alert	The moment any of our tools first noticed something. It usually comes hours before confirmation, and some deadlines start counting from here, so they can be running before anyone has confirmed anything.
Milestone	One thing a law requires us to do, with its own time limit. Example: "send an initial report to the authority within N hours". Read from the law's PDF.
Exemption	A situation where customers do not need to be told, for example if the leaked data was protected in a way the EU procedure says is safe. The system reads which situations count from the PDF and never guesses.
The human sign-off	The point where the system stops and waits for the Data Protection Officer. Nothing is sent to an authority or a customer until a person decides. The pause is saved, so it survives a restart.
Filing buffer	A few hours kept aside for writing and sending the report. Time available = time to the earliest deadline minus this buffer.
Same answer for everyone	If a communications agent asks about an incident that hasn't been made public, they get the same refusal whether it exists or not. Asking can't reveal that something is being kept quiet.
Data Protection Officer (DPO)	The person responsible for data-protection law at the company. In BreachWatch, the only person allowed to decide whether to notify a regulator or customers.

14 Appendix: technical reference

For engineers: the technical names behind the plain-English descriptions.

A.1 Technology

Concern	Technology
Data cleaning & models	pandas, scikit-learn (pipelines with built-in preparation)
Document library	PDF text extraction, ChromaDB vector store, cosine distance
AI workflow	LangGraph state graph with interrupt + SQLite checkpointer; Gemini via .env
Back-end service	FastAPI with Pydantic schemas, session-token guard
Database	SQLAlchemy over SQLite (six tables)
Dashboard	Streamlit, five pages, all figures fetched from the service

A.2 Reporting procedures

Code (config)	Document	Applies when

`PROCEDURE_EU_PERSONAL_DATA_BREACH`	`Procedure-01-EU-Personal-Data-Breach.pdf`	`personal_data_involved_flag = Yes`
		`eu_data_subjects_count ≥ 1`
		`harm_band ∈ EU_PROCEDURE_HARM_BANDS`

`PROCEDURE_SIGNIFICANT_INCIDENT`	`Procedure-02-Significant-Incident-Reporting.pdf`	`outage > SIGNIFICANT_OUTAGE_MINUTES`
		`or campaign customers > SIGNIFICANT_CUSTOMERS_ACROSS_CAMPAIGN`
		`or direct loss > SIGNIFICANT_DIRECT_LOSS_EUR`

`PROCEDURE_INDIA_CYBER_INCIDENT`	`Procedure-03-India-Cyber-Incident-Reporting.pdf`	`hosting_region ∈ INDIA_HOSTING_REGIONS` `or india_data_subjects_count ≥ 1`

A.3 Workflow nodes

Node	Agent name	Reply fields	LLM calls
`load_incident_context`	—	—	0
`plan_assessment`	`incident_intake_planner`	`PRIORITY · CHECKS · RATIONALE`	1
`assess_harm`	`harm_analyst`	`DRIVERS · PROTECTION · HARM SUMMARY`	1
`identify_attack`	`attack_analyst`	`ATTACK TYPE · CONFIDENCE · EVIDENCE`	1

check_reporting_duties	reporting_duty_advisor	AUTHORITIES · DEADLINES · CUSTOMER NOTICE	1
compose_incident_assessment	incident_writer	ASSESSMENT · RECOMMENDED DISPOSITION	1
request_dpo_decision	—	—	0
draft_customer_notice	customer_notice_agent	SUBJECT · NOTICE	1
draft_regulator_filing	regulator_filing_agent	SUMMARY · SECTIONS · CUSTOMERS	1
record_incident_outcome	—	—	0

A.4 Models

Model	Type	Target	Pass mark
Risk model	Binary classifier (e.g. HistGradientBoosting)	high_risk_to_individuals (0/1)	roc_auc ≥ MINIMUM_HARM_ROC_AUC
Workload model	Regressor (native-category gradient boosting)	containment_hours	r2 ≥ MINIMUM_EFFORT_R2 and beats the average-answer baseline
Notes reader	Text classifier (TF-IDF + linear model)	attack_type (8 classes)	macro_f1 ≥ MINIMUM_ATTACK_MACRO_F1

A.5 REST endpoints

Method	Path	Purpose
POST	/auth/signin	Exchange username + password for a session token
POST	/auth/signout	End the session
GET	/queue	Ranked incident queue, filterable by harm band
GET	/queue/{incident_reference}	Everything the tools establish about one incident (no LLM)
POST	/assessments	Run the workflow to the gate (5 LLM calls)
GET	/incidents	Assessments by status (decision queue / audit trail)
POST	/incidents/{assessment_id}/decision	Record the DPO decision and resume (DPO only)
GET	/incidents/{assessment_id}/calls	Call budget: actual vs. expected LLM calls
POST	/chat/ask	One grounded chat answer (1 LLM call)
GET	/chat/turns	The signed-in person's own chat history
GET	/audit/chat-turns	Everyone's recent chat turns (audit area)

Errors: 401 not signed in · 403 role does not reach the area · 404 unknown incident/assessment · 409 already decided · 422 invalid value · 502 language-model failure (with the reason).

A.6 Database tables

Table	Holds
`user_accounts`	Sign-in accounts: role, salted password hash, current session token
`agent_runs`	Each workflow run: thread id, status, LLM call count, start/finish
`security_incidents`	Each assessment: facts, deadlines, effort, agent text, recommendation, documents, status
`dpo_decisions`	Each decision: disposition, who, role, reason, when
`llm_calls`	Each language-model call: agent, model, sizes, latency
`chat_turns`	Each chat question: who, type, answer, sources, distance, refused